

Policy Owner	Effective Date	Version	Next Review Date
IT Director / HIPAA Security Officer	June 10, 2026	1.0	June 10, 2027

PURPOSE:

The purpose of this policy is for establishing a framework that classifies data of the organization based on value and sensitivity. This is to ensure protected health information(PHI) and other sensitive data are handled so that confidentiality, integrity, and availability is preserved. The policy supports compliance with the HIPAA Privacy and Security Rules as well as the Minimum Necessary Standard that requires access to PHI to be limited to the minimum amount necessary to perform a given job function.

SCOPE:

This policy applies to all staff of the organization, as well as contractors, third-party vendors and other individuals who may interact with the organization's data or systems regardless of location or employment type.

ROLES & RESPONSIBILITIES:

1. Treating Physician - The general doctor will have access to the data of the patient they are treating, it is critical for them to do their job correctly. They will not have access to any data of the patients which they are not serving.
2. Supporting Staff - Staff which manage and support the patient's treatment will have access to data on a NEED TO KNOW basis to be able to perform their job.
3. Chief Medical Officer (CMO) - The CMO will have access to all data of patients and will be in charge of granting data access as needed for job duties.
4. IT Director / HIPAA Security Officer- The IT Department Head will have the ability to grant data access as needed for job duties. They are the owner of the policy and conductor of annual policy review.
5. IT Team - Enforcers of the technical access controls, violation monitoring
6. Department Managers - Ensuring compliance from their staff.
7. Billing Department - Access to minimum necessary PHI for claims processing only

POLICY STATEMENTS:

1.1 - Employees will only have access to data on a NEED TO KNOW basis. An employee will not have access to data unless it is required for them to perform their duties

1.2 - Employees are prohibited from accessing data to which they have no permission to access. This means using accounts with higher privilege in systems to circumnavigate their lower privilege accounts.

1.3 - Leakage of data for profit, malicious intent, or for any reason is prohibited and will lead to termination of employment as well as referral to the appropriate legal authorities.

1.4 - Data must always be properly handled to ensure that only the person with the privilege to view the data is able to view it. Meaning to ensure screens cannot be seen by outsiders, other employees, etc. Failure to ensure PHI is secured from unauthorized view may constitute a violation of HIPAA.

1.5 - Data is broken down into 4 tiers:

1. Tier 1 - Public: Information Outlast intentionally wants to be externally available such as clinic location, hours, phone number, etc.

2. Tier 2 - Internal: Information that is meant for all employees to access but not for outside eyes. This includes internal memos, staff schedules, general operational procedures, etc

3. Tier 3 - Confidential: Information that is limited access as it is sensitive and relating to the business. This can include employee personnel files, payroll data, vendor contracts, billing records, etc.

4. Tier 4 - Restricted: The highest protection tier. This includes all protected health information such as records, prescriptions, diagnoses, treatment plans, medical histories, etc. Data must be handled according to the guidelines that HIPAA sets out.

1.6 - Tier 4: Restricted data must be encrypted at all times whether at rest or in transit.

1.7 - Tier 4: Restricted data is prohibited from being transmitted over standard email. Only secure and encrypted channels of communication may be used.

1.8 - Tier 3: Confidential data can only be stored in access-controlled systems, never stored on personal devices.

1.9 - Tier 1: Public data must have approval from the IT Director or CMO before publication externally

1.10 - Physical documents containing Tier 3 or Tier 4 data must be stored in locked filing cabinets and shredded when no longer needed.

COMPLIANCE & ENFORCEMENT:

Failure to comply with the Data Classification Policy will lead to termination of employment as well as referral to the appropriate legal authorities depending on severity. Violations involving (PHI) may constitute a breach under HIPAA which will be reported to the appropriate regulatory authorities which include the U.S. Department of Health and Human Services (HHS) Office for Civil Rights.

EXCEPTIONS:

Exceptions to this policy must be put into a written request form and sent to the IT team and/or the CMO and approved by the head of the IT department or CMO.

REVIEW CYCLE:

This policy will be reviewed annually or after any significant security incident.

VERSION HISTORY TABLE:

Version	Date	Author	Description of Changes
1.0	6/10/2026	Bryan Alcivar	Initial Policy Creation